RISKO / ENTERPRISE RISK MANAGEMENT PLATFORM

MANUAL DE PRESENTACIÓN & FICHA TÉCNICA

YOU OWN THE RISK. YOU CONTROL THE OUTCOME.

Todo lo que necesita tu gestión de riesgo corporativo y operacional, en un solo lugar.
Una plataforma concebida para interconectar proyectos, procesos de negocio, inventario integral de riesgos, análisis de causas y consecuencias, parametrización y evaluación de solidez de controles, gestión forense de eventos de pérdida y planes de tratamiento con trazabilidad total.

VISIBILIDAD PARA DIRIGIR	CONTEXTO PARA DECIDIR	TRAZABILIDAD PARA AUDITAR
Monitoreo continuo mediante Dashboard ejecutivo y Mapas de Calor con cálculo en tiempo real.	Vínculo biunívoco entre macroprocesos, riesgos inherentes, solidez de controles y eventos de pérdida.	Evidencia documental fechada, evaluación tripartita de controles y responsables identificables con firma.

DOCUMENTO CONFIDENCIAL: Visión de producto, arquitectura modular y especificación funcional técnica preparada para Comités de Riesgo, Auditores y Dirección General. Versión 1.0 / Octubre 2026.

La información conectada transforma la gestión del riesgo.

RISKO propone una visión compartida del riesgo, con responsables, controles y evidencias identificables.

Sustituye matrices aisladas en hojas de cálculo por una arquitectura relacional sólida y auditable.

01

Ver lo importante

Reunir el estado de salud de los procesos, el inventario de riesgos, la solidez de los controles, los eventos de pérdida y los planes de mitigación en un único punto de entrada unificado y adaptado al perfil del usuario.

02

Coordinar con contexto

Relacionar proyectos corporativos, procesos de negocio, causas raíz, riesgos inherentes, controles mitigadores e incidentes materializados sin duplicar registros ni generar silos informativos.

03

Conservar la evidencia

Vincular cada control y plan con responsables concretos, fechas compromiso, evidencias documentadas y porcentajes de solidez de diseño, ejecución y efectividad real comprobable.

Impacto Estratégico: Valor esperado: Reducción drástica de la dispersión informativa, mayor solidez ante auditorías internas y externas, y toma de decisiones basada en datos reales. Los beneficios se calibran en fases piloto controladas.

Un entorno colaborativo para las Tres Líneas de Defensa.

Roles organizacionales y necesidades clave que el diseño de RISKO busca resolver.

Plataforma adaptable a corporaciones financieras, industriales, de servicios y firmas de auditoría.

1ª LÍNEA

Dueños de Procesos & Operación

Líderes de unidades operativas y de soporte que gestionan las actividades cotidianas.

- Identifican y reportan riesgos en sus áreas.
- Ejecutan los controles asignados y adjuntan evidencias.
- Reportan oportunamente eventos e incidentes de pérdida.
- Lideran y ejecutan las actividades de los planes de acción.

2ª LÍNEA

Gestión de Riesgo & Cumplimiento

Oficiales de Riesgo (CRO), Oficiales de Cumplimiento y Comités especializados.

- Definen las metodologías y parametrizan la matriz de calor.
- Evalúan la solidez de diseño y ejecución de los controles.
- Monitorean la migración de riesgo inherente a residual.
- Administran el catálogo institucional y coordinan evaluaciones.

3ª LÍNEA & DIRECCIÓN

Auditoría Interna & Comités

Auditores Internos, Junta Directiva y Alta Dirección General.

- Acceso a tableros ejecutivos y mapas de aseguramiento.
- Verificación independiente de efectividad de controles.
- Trazabilidad histórica de eventos y planes correctivos.
- Cumplimiento con marcos ISO 31000, COSO ERM e ISO 27001.

Gobierno de Acceso: Usuarios y permisos: Administración, Gestores de Riesgo, Auditores, Dueños de Procesos y Consultores. Perfiles con acceso restringido bajo estricta segregación de funciones (SoD).

Dashboard & Administración del Sistema

Una vista global y ejecutiva orientada al seguimiento diario del riesgo organizacional.

Acceso seguro, configuración de usuarios y delimitación de privilegios de seguridad.

DASHBOARD

Indicadores Clave y Resumen

Tarjetas de consolidación en tiempo real:

- Total de **Procesos** mapeados en la organización.
- Conteo de **Riesgos** activos en inventario.
- Número de **Controles** parametrizados y evaluados.
- Registro de **Eventos** materializados.
- Estado de avance de **Planes de Acción**.
- Campañas de **Evaluación** en ejecución.

USUARIOS

Perfiles y Datos Laborales

Gestión centralizada de colaboradores:

- Expediente con nombres, correo, dependencia y cargo.
- Historial laboral y datos de contacto corporativo.
- Asignación como responsables en proyectos, procesos, controles, eventos y planes.
- Mecanismos seguros de actualización y cambio de contraseñas.

SEGURIDAD

Roles y Permisos Granulares

Control de acceso basado en roles (RBAC):

- Configuración de matrices de privilegios de seguridad.
- Segregación formal de funciones entre quien diseña el control, quien lo ejecuta y quien lo audita.
- Registro inmutable de transacciones y accesos por usuario.
- Protección de datos sensibles e integridad de auditoría.

Regla de Oro: Cada usuario visualiza únicamente lo pertinente a su nivel de responsabilidad y actúa bajo estricta segregación de funciones.

Proyectos y Portafolios Estratégicos

Organización de los análisis de riesgos por carteras, subsidiarias o iniciativas clave.

Delimitación del alcance organizacional y asignación clara de responsabilidades de gobierno.

PORTAFOLIO

Proyectos Corporativos

Estructuración del ámbito de gestión:

• Registro y agrupación de proyectos de transformación, líneas de negocio o empresas del grupo corporativo.
• Delimitación clara del alcance operativo y temporal.
• Visibilidad comparativa de exposición al riesgo entre proyectos.
• Base para la consolidación del perfil de riesgo institucional.

GOBIERNO

Asignación de Responsables

Rendición de cuentas (Accountability):

• Vinculación de equipos responsables por proyecto.
• Identificación del patrocinador y líderes técnicos con su respectiva dependencia y cargo formal.
• Claridad de atribuciones para la toma de decisiones y aprobación de planes de contingencia.

ALCANCE

Contextualización del Riesgo

Definición del entorno operativo:

• Descripción detallada de objetivos, recursos y restricciones de cada proyecto.
• Enlace directo con la arquitectura de procesos asociados.
• Facilidad para segmentar reportes de riesgos para juntas directivas o comités de auditoría específicos.

Criterio de Aplicación: Un proyecto define los límites organizacionales, los recursos y los responsables bajo los cuales se identifican y gestionan los procesos y riesgos.

Arquitectura de Procesos de Negocio

Base estructural para vincular la gestión del riesgo con la cadena de valor institucional.

Clasificación estandarizada, codificación unificada y dueños de proceso identificados.

TIPOLOGÍA

Clasificación Estandarizada

Categorización según mejores prácticas:

• **Estratégicos:** Procesos de dirección, planificación institucional y gobierno corporativo.
• **Operativos (Misionales):** Procesos que componen la cadena de valor y entregan el producto o servicio.
• **De Soporte (Apoyo):** Procesos auxiliares como tecnología, compras, talento humano y finanzas.

ESTRUCTURA

Jerarquía y Codificación

Organización del inventario de procesos:

• Código único de identificación institucional por proceso.
• Agrupación por categorías, unidades operativas y proyectos vinculados.
• Descripción detallada de entradas, actividades y salidas clave.
• Mapeo transparente para auditorías de calidad (ISO 9001).

PROPIEDAD

Dueños de Proceso & Riesgos

Custodia activa y gobernanza:

• Asignación formal de colaboradores como Dueños de Proceso.
• Enlace biunívoco con los riesgos que pueden impedir el cumplimiento de las metas del proceso.
• Visualización inmediata de la densidad de riesgo por unidad operativa de la empresa.

Principio de Custodia: No existe riesgo huérfano: cada vulnerabilidad o amenaza se ancla formalmente a un proceso y a un responsable de custodia.

Inventario Integral y Evaluación de Riesgos

Catálogo sistemático para la identificación, ponderación y cálculo del Riesgo Inherente.

Valoración estructurada de impacto y probabilidad según el apetito de riesgo corporativo.

CATÁLOGO

Identificación y Registro

Caracterización rigurosa del evento adverso:

- Nombre y denominación técnica del riesgo.
- Descripción detallada de las circunstancias de materialización.
- Nivel de afectación potencial institucional.
- Asignación de colaboradores responsables del monitoreo continuo.
- Vinculación con los procesos de negocio amenazados.

VALORACIÓN

Impacto y Frecuencia Ponderados

Cuantificación paramétrica del riesgo:

- **Impacto:** Calificación de severidad y peso ponderado (impactWeight) del daño potencial.
- **Frecuencia:** Calificación de probabilidad de ocurrencia y peso ponderado (frequencyWeight).
- Flexibilidad para incorporar criterios financieros, operacionales, legales y reputacionales.

INHERENTE

Determinación de Exposición Pura

Nivel de Riesgo Inherente:

- Cálculo automático de la severidad antes de considerar la acción mitigatoria de los controles.
- Clasificación por cuadrantes de criticidad.
- Ubicación inmediata en la matriz de calor institucional.
- Punto de partida objetivo para el diseño de controles.

Nota Metodológica: El Riesgo Inherente refleja la vulnerabilidad cruda de la organización; su mitigación depende exclusivamente de la solidez demostrable de los controles.

Análisis Causal y Afectaciones

Desglose de los factores de origen raíz y dimensionamiento del daño potencial.

Modelado de relaciones de causa-efecto para prevenir la materialización recurrente.

CAUSA RAÍZ

Factores Desencadenantes

Identificación de los motivos de falla:

• **Factores Humanos:** Falta de capacitación, omisión, fatiga o errores de procedimiento.
• **Factores Tecnológicos:** Caídas de sistemas, obsolescencia, brechas de ciberseguridad.
• **Factores de Proceso:** Diseños ambiguos, cuellos de botella o controles inexistentes.
• **Factores Externos:** Normativa, proveedores, clima o mercado.

CONSECUENCIA

Dimensionamiento del Daño

Afectaciones directas e indirectas:

• Pérdidas económicas y costos de remediación.
• Paralización o degradación de operaciones críticas.
• Sanciones regulatorias, multas o demandas legales.
• Impacto en la reputación institucional y pérdida de clientes.
• Afectaciones a la seguridad de colaboradores o terceros.

CONEXIÓN

Trazabilidad Causal Total

Vínculo integral en el ecosistema:

• Cada causa se asocia formalmente al riesgo correspondiente.
• Al ocurrir un evento, se identifica exactamente qué causa fue la detonante.
• Los controles y planes de acción se diseñan para neutralizar la causa y no solo aliviar el síntoma.

Enfoque Preventivo: Mitigar las causas evita la materialización del riesgo; cuantificar las consecuencias permite priorizar racionalmente la inversión en controles.

Controles y Evaluación de Solidez

Modelado de defensas preventivas, detectivas y correctivas con evaluación tripartita.

Parametrización dinámica para calificar diseño, ejecución y efectividad comprobable.

ATRIBUTOS

Tipología y Formalidad

Clasificación y naturaleza del control:

- **Tipo de Ejecución:** Preventivo (evita la causa), Detectivo (alerta la ocurrencia) o Correctivo (reduce el impacto).
- **Frecuencia:** Continuo, diario, semanal, mensual o periódico.
- **Documentación:** Manuales, políticas, procedimientos aprobados.
- **Responsable:** Colaborador encargado de su operación diaria.

SOLIDEZ

Evaluación Tripartita de Eficacia

Medición analítica de la robustez del control:

- **Solidez de Diseño (% diseño):** ¿El control está bien estructurado para neutralizar el riesgo?
- **Solidez de Ejecución (% ejecución):** ¿Se aplica con la frecuencia y en el momento oportuno?
- **Solidez de Resultado (% efectividad):** ¿Existe evidencia comprobable de que mitigó incidentes pasados?

PARÁMETROS

Configuración Dinámica

Adaptabilidad al marco corporativo:

- Parametrización modular de criterios de evaluación.
- Ponderación de pesos porcentuales por tipo de control.
- Vinculación simultánea de un control a múltiples riesgos y procesos.
- Registro de eventos históricos asociados al control.

Criterio de Auditoría: Un control documentado que carece de evidencia periódica de ejecución pierde validez metodológica para reducir el riesgo residual.

Gestión Forense de Eventos de Riesgo

Registro sistemático de eventos materializados, tiempos de respuesta y cálculo de pérdidas.

Diagnóstico de causas desencadenantes y análisis de fallas en los controles existentes.

REGISTRO

Ficha Forense del Evento

Detalle cronológico y espacial del incidente:

- Denominación formal y descripción circunstanciada.
- Lugar físico o lógico donde ocurrió el evento.
- **Fecha y Hora de Ocurrencia:** Momento exacto de la falla.
- **Fecha y Hora de Descubrimiento:** Momento en que la organización tomó conocimiento formal.
- Medición de la brecha temporal de detección.

PÉRDIDAS

Criticidad y Cuantificación

Evaluación del daño real sufrido:

- Calificación del nivel de criticidad del evento.
- Indicador explícito de **Generación de Pérdida** (generateLoss).
- Registro del monto económico de la pérdida financiera, penalizaciones o lucro cesante.
- Estado del evento (Abierto, En Investigación, Mitigado, Cerrado).

DIAGNÓSTICO

Causas y Controles Fallidos

Cierre de la brecha de control:

- Asociación con los procesos de negocio impactados.
- Identificación del riesgo institucional materializado.
- Enlace con las causas raíz que propiciaron el incidente.
- Identificación de los controles que fallaron o resultaron insuficientes para alimentar los planes de mejora.

Métrica Clave: Registrar con precisión la brecha entre la ocurrencia y el descubrimiento es el principal indicador de la oportunidad de los controles detectivos.

Planes de Acción y Mitigación

Estrategias estructuradas para subsanar debilidades, tratar riesgos o responder a eventos.

Cronograma de actividades operativas con asignación de ejecutores y fechas de entrega.

ESTRATEGIA

Definición del Plan

Planificación formal del tratamiento:

- Nombre y descripción del objetivo de mitigación.
- **Fecha de Inicio** y **Fecha Límite** de implementación.
- Asignación de colaboradores responsables de liderar el plan.
- Estimación de recursos y presupuesto requerido para el tratamiento del riesgo.

ACTIVIDADES

Desglose Operativo Fechado

Ejecución granular de compromisos:

- Desglose en actividades específicas calendarizadas.
- Asignación de ejecutores particulares para cada tarea.
- Seguimiento de avance porcentual de cada actividad.
- Evidencia de cumplimiento previo al cierre formal del hito.

INTEGRACIÓN

Articulación Multidimensional

Impacto directo en el sistema de gestión:

- Vinculación con los **Riesgos** a mitigar.
- Enlace con los **Eventos** de pérdida que motivaron la acción correctiva.
- Asociación con los **Procesos** donde se implementa la mejora.
- Creación o refuerzo de **Controles** derivados del plan.

Regla Operativa: Un plan de acción sin actividades fechadas, entregables medibles y responsable directo asignado es solo una declaración de intenciones.

Campañas de Evaluación Periódica

Ciclos sistemáticos de revisión para auditar controles y recalificar el Riesgo Residual.

Formalización del aseguramiento para comités ejecutivos y organismos reguladores.

CAMPAÑAS

Planificación de Evaluaciones

Organización de ciclos de revisión:

- Creación de campañas trimestrales, semestrales o anuales.
- Delimitación temporal: Fecha de Inicio y Fecha de Cierre.
- Clasificación por Tipo de Evaluación (Control Interno, Auditoría de Riesgos, Evaluación Regulatoria).
- Definición del alcance de procesos y controles a auditar.

AUDITORES

Equipo Evaluador y Evidencia

Rigurosidad metodológica en el terreno:

- Asignación de evaluadores y auditores autorizados.
- Interacción con los responsables de los controles.
- Revisión de muestras, registros de evidencia y pruebas de recorrido.
- Sustentación documentada de cada calificación otorgada.

RESIDUAL

Recalificación del Riesgo

Determinación del Riesgo Residual:

- Ajuste formal de los niveles de impacto y frecuencia tras verificar la efectividad de los controles.
- Generación del mapa de calor de Riesgo Residual.
- Comprobación de que la exposición neta se sitúe dentro de los límites de tolerancia institucional.

Garantía de Gobierno: La evaluación periódica formaliza la vigencia de los controles y proporciona el respaldo probatorio exigido por los Comités de Auditoría.

Mapa de Calor y Parametrización

Matriz interactiva de severidad para la toma de decisiones directivas y priorización.

Configuración flexible de escalas, pesos ponderados y cuadrantes de criticidad.

ESCALAS

Parametrización Dinámica

Configuración a medida de matrices:

• **Impacto:** Niveles parametrizables (ej. Insignificante, Menor, Moderado, Mayor, Catastrófico) con pesos numéricos y porcentajes.
• **Frecuencia:** Niveles configurables (ej. Improbable, Posible, Ocasional, Probable, Frecuente) con ponderación específica.
• Adaptación a matrices estándar 3x3, 4x4 o 5x5.

MATRIZ

Visualización por Cuadrantes

Zonificación térmica de la severidad:

• Código de colores institucional: Verde (Bajo/Tolerable), Amarillo (Medio), Naranja (Alto) y Rojo (Crítico/Extremo).
• Densidad visual inmediata: concentración de riesgos por celda.
• Acceso interactivo: clic en la celda para listar los riesgos asociados y sus expedientes.

MIGRACIÓN

De Inherente a Residual

Visualización gráfica del efecto mitigador:

• Comparación visual entre la matriz de Riesgo Inherente (bruto) y la matriz de Riesgo Residual (neto).
• Comprobación gráfica del desplazamiento de los riesgos hacia zonas seguras gracias a los controles.
• Identificación rápida de riesgos que permanecen en zona roja.

Comunicación Ejecutiva: El mapa de calor sintetiza la complejidad técnica del riesgo en un lenguaje visual claro para la Alta Dirección y la Junta Directiva.

Un Caso de Uso Conectado: Del Proceso al Cierre

Ejemplo conceptual de interconexión transversal de registros en una misma operación.

Demostración de trazabilidad completa entre áreas sin duplicar información ni perder controles.

1 / CONTEXTUALIZAR | Proyectos + Procesos

Se identifica el macroproceso de negocio ('Tesorería') dentro del proyecto corporativo. Se asigna formalmente al Dueño del Proceso responsable de la custodia.

2 / IDENTIFICAR | Riesgos + Causas

Se registra el riesgo de 'Pagos duplicados no detectados'. Se asocian causas raíz (error manual y falta de validación bancaria) y se calcula su Riesgo Inherente (Alto) en el Mapa de Calor.

3 / MITIGAR | Controles

Se diseña un control preventivo: 'Conciliación bancaria automatizada'. Se evalúa su solidez de diseño (90%) y se asigna al responsable de tesorería para su ejecución diaria con evidencias.

4 / EVALUAR | Evaluaciones Periódicas

El comité auditor abre la campaña de evaluación semestral. Audita las evidencias del control bancario, certifica su efectividad y recalifica el Riesgo Residual a nivel Bajo/Tolerable.

5 / REGISTRAR EVENTO | Eventos

Si ocurre un incidente, se registra la fecha/hora de ocurrencia, fecha/hora de descubrimiento, monto de la pérdida económica y se asocia al control que sufrió la brecha operativa.

6 / TRATAR Y SUBSANAR | Planes de Acción

Se formula un Plan de Acción correctivo con tres actividades calendarizadas para fortalecer el control y evitar recurrencias. El plan se monitorea hasta su cierre formal auditado.

Trazabilidad Integral: Una única cadena de registros compartidos conecta la estrategia con la operación diaria, preservando quién decide, quién ejecuta y quién firma.